

IT Security Audit Report: Midwest Central Bank

Cybersecurity Risk Assessment & Compliance Review

Executive Summary

Our assessment of Midwest Central Bank's IT infrastructure uncovered serious security weaknesses that leave the organization vulnerable to ransomware, data breaches, and regulatory penalties. The bank's legacy systems lack fundamental protections like multi-factor authentication and adequate monitoring. Currently, the organization meets only about half of mandatory GLBA and PCI DSS requirements. Without immediate action, the bank faces substantial financial and security risks.

Methodology & Sources

We structured this audit around the NIST Cybersecurity Framework, evaluating technical controls against GLBA Safeguards Rule requirements and PCI DSS v4.0 standards. Our threat analysis drew from FBI Internet Crime Complaint Center reports, CISA security advisories, and the 2024 Verizon Data Breach Investigations Report for the financial services sector. We prioritized risks using a likelihood vs. impact model based on industry breach data showing average financial institution breach costs of \$5.9 million.

Key Findings

The audit revealed six major security gaps:

Outdated Infrastructure - Core servers run Windows Server 2008 and 2012, both past Microsoft's support end dates. These systems have known vulnerabilities with publicly available exploits that attackers actively target.

Missing Multi-Factor Authentication - Neither privileged accounts nor customer facing systems require MFA. Microsoft's research shows that this single control blocks 99% of automated credential attacks.

Poor Network Design - The flat network architecture lets attackers move freely between systems once they gain initial access. There's no segmentation isolating critical financial data from general office systems.

Inconsistent Patching - Roughly 60% of systems have critical patches overdue by more than 30 days, including fixes for vulnerabilities that CISA flags as actively exploited in the wild.

Weak Encryption - Customer data moves between systems without consistent end-to-end encryption, and stored cardholder data lacks encryption at rest; both clear PCI DSS violations.

IT Security Audit Report: Midwest Central Bank

Cybersecurity Risk Assessment & Compliance Review

No Real-Time Monitoring - Without a SIEM solution, the bank can't detect ongoing attacks. Industry data shows organizations without monitoring take over 200 days on average to discover breaches.

Compliance Status

GLBA deficiencies include an outdated risk assessment (last updated 2018), insufficient access controls, inadequate encryption practices, and employee training that covers only basic compliance without testing security awareness through realistic scenarios.

PCI DSS violations center on missing MFA (Requirement 8), lack of cardholder data encryption at rest (Requirement 3), inadequate monitoring and logging (Requirement 10), and inconsistent vulnerability management (Requirement 6). Overall compliance stands at approximately 52%, which is well below acceptable figures, which puts the bank at risk to regulatory action.

Recommendations

Immediate Priorities (0-3 Months)

Deploy Multi-Factor Authentication on all privileged accounts and online banking systems first. Use phishing resistant methods like hardware tokens or biometrics where possible. Cost: ~\$50K.

Implement SIEM Monitoring to detect suspicious activity in real-time. Cost: ~\$120K annually.

Short-Term Initiatives (3-12 Months)

Redesign network architecture to segment critical systems from general networks. Apply zero-trust principles so systems verify every access attempt. Cost: ~\$200K.

Modernize Legacy Systems through phased migration from unsupported operating systems to current versions. Prioritize online and financial transaction systems. Cost: \$500K-\$1M

Add Endpoint Protection with EDR tools that detect attacks and provide detailed forensics. Cost: ~\$80K annually.

Create Incident Response Plan with clear procedures, designated roles, and quarterly practice exercises. Cost: ~\$40K.

Long-Term Strategy (12+ Months)

IT Security Audit Report: Midwest Central Bank

Cybersecurity Risk Assessment & Compliance Review

Consider cloud migration for better security and disaster recovery, establish 24/7 security monitoring through an internal SOC or managed service provider, and conduct regular penetration testing to validate improvements.